

RED TEAM ENGAGEMENT REPORT

OPERACIÓN DARK GATE — Lab-03

CAMPO	DETALLE
Nombre de operación	DARK GATE
Clasificación	CONFIDENCIAL — Solo uso educativo
Adversario emulado	APT29 (Cozy Bear) — SVR Rusia
Objetivo primario	Certificado de Administrador + persistencia post-rotación de contraseña
Objetivo secundario	ESC4: comprometer plantilla → certificado DA permanente
Entorno	attackcorp.local con ADCS (CA Enterprise, plantillas vulnerables)
Período	16/05/2026 — 17/05/2026
Operador	Adrián Camacho

1. RESUMEN EJECUTIVO

La operación DARK GATE emula las TTPs de APT29 en la explotación de Active Directory Certificate Services (ADCS). Se identificaron y explotaron tres vectores de ataque (ESC1, ESC4 y ESC8 identificado) en la infraestructura PKI del dominio. La técnica más crítica fue ESC4 — la modificación de una plantilla de certificado para obtener un certificado de autenticación como Domain Administrator que permanece válido independientemente de cambios de contraseña, proporcionando persistencia indefinida en el dominio.

2. ADCS — VULNERABILIDADES IDENTIFICADAS

VECTOR	PLANTILLA	DESCRIPCIÓN	EXPLOTADO
ESC1	VulnerableUserAuth	CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT + Client Auth Cualquier usuario puede solicitar cert como Administrador	SI
ESC4	VulnerableTemplate	fin.garcia tiene WriteDacl + WriteProperty sobre la plantilla Modificación para ESC1 → cert DA	SI
ESC8	Machine Template	NTLM relay a /certsrv identificado KB5005413 bloquea relay SMB→HTTP en WS2022	PARCIAL

3. KILL CHAIN

FASE	TÉCNICA	RESULTADO	MITRE
1 — Enum	Certipy find	ESC1 + ESC4 identificados en plantillas	T1046
2 — ESC1	Certipy req (SAN = Administrador)	Certificado Administrador.pfx obtenido	T1649
2 — ESC1	Certipy auth (PKINIT)	TGT + hash NT Administrador via PKINIT	TT1558
3 — ESC4	Certipy template (modify)	Plantilla VulnerableTemplate → ESC1	T1484

3 — ESC4	Certipy req + restore	Cert DA + plantilla restaurada (OPSEC)	T1649
4 — ESC8	ntlmrelayx identificado	Relay identificado — KB5005413 bloqueado	T1557S2022
5 — C2	Sliver beacon + cert	Beacon CLINICAL_CHAIRMAN activo en T1071	T1071
6 — Persist	Certificado post-rotación	Cert válido tras cambio de contraseña de Administrador	T1649

4. IMPACTO DE PERSISTENCIA VIA CERTIFICADO

El vector más crítico de esta operación es la persistencia via certificado digital. Un certificado de autenticación obtenido via ESC1/ESC4 permanece válido durante 1-2 años, independientemente de:

- Cambios de contraseña de la cuenta comprometida
- Reset del hash de krbtgt (invalida Golden Tickets pero NO certificados)
- Respuesta a incidentes que no incluya revocación explícita del certificado
- Rotación de credenciales por políticas de seguridad

5. RECOMENDACIONES

PRIORIDAD	RECOMENDACIÓN
CRÍTICA	Deshabilitar CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT en todas las plantillas de autenticación
CRÍTICA	Auditar todos los certificados emitidos — revocar certificados sospechosos en la CA
CRÍTICA	Habilitar "CA Manager Approval" para plantillas de autenticación de alta privilegio
ALTA	Revisar permisos de todas las plantillas — nadie excepto Domain Admins debe tener WriteProperty
ALTA	Implementar monitorización de Event IDs 4886/4887/4899/4900 en la CA
ALTA	Aplicar KB5005413 y habilitar EPA en IIS del servidor ADCS para mitigar ESC8
MEDIA	Reducir validez de certificados de 2 años a 6 meses para minimizar ventana de exposición
MEDIA	Implementar OCSP Stapling + CRL Distribution Points para revocación efectiva